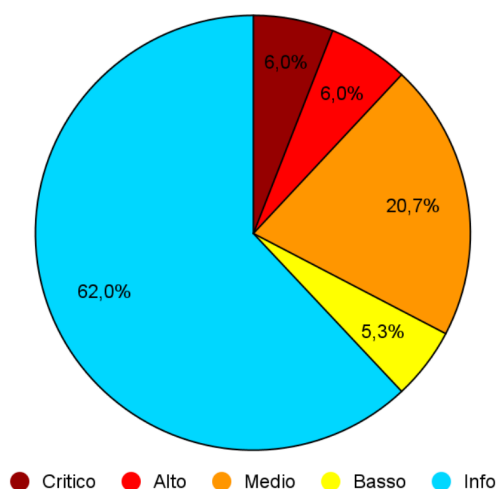


Analisi vulnerabilità e azioni di rimedio

In questo progetto di fine modulo viene assegnata una delle fasi del Penetration Test: l'**analisi delle vulnerabilità**. Per eseguire questa scansione ci siamo attrezzati di un tool chiamato **Nessus**, uno scanner di vulnerabilità il quale è stato scaricato ed installato nella nostra VM Kali Linux.

In questo progetto abbiamo usato un client (Kali) con ip 192.168.50.100 e un target (Metasploitable) con ip 192.168.50.101 e che operano in una rete interna.

Una volta avviato Nessus da Kali iniziamo a cercare le possibili vulnerabilità di Metasploitable evidenziando il livello di criticità di ogni debolezza riscontrata.



In questo grafico è possibile osservare quante debolezze, o vulnerabilità, sono state individuate durante la scansione. Come possiamo ben vedere il target della nostra scansione risulta molto vulnerabile, questo in parte è dovuto al fatto che il target utilizzato è reso volontariamente vulnerabile in modo da capire come poter proteggere o attaccare la macchina.

Una volta completata la scansione ed individuate tutte le vulnerabilità e la loro criticità andiamo ad effettuare le “soluzioni” delle potenziali in modo da riuscire a rendere la macchina target più “sicura”.

VCN Server ‘password’ Password

Questa è una debolezza con un livello di criticità 10.0 (il più elevato). Il server VCN in esecuzione sull’host remoto è protetto da una password debole. Questo potrebbe permettere ad un possibile aggressore di entrare con facilità e prendere il controllo del sistema.

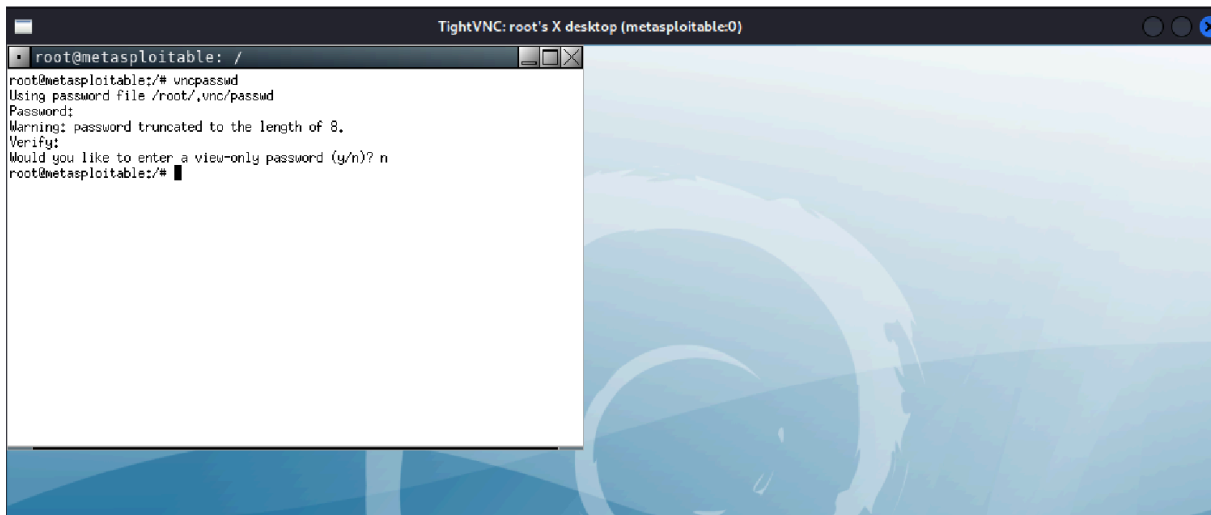
La soluzione per risolvere questa vulnerabilità è quella di cambiare la password tramite terminale di metasploitable, in alternativa possiamo anche cambiarla tramite Kali connettendosi alla VCN.

metodo metasploitable

```
root@metasploitable:~# vncpasswd
Using password file /root/.vnc/passwd
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? n
root@metasploitable:~#
```

metodo Kali

```
(kali@kali)~$ vncviewer 192.168.50.101:5900
Connected to RFB server, using protocol version 3.3
Performing standard VNC authentication
Password:
Authentication successful
Desktop name "root's X desktop (metasploitable:0)"
VNC server default format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
Using default colormap which is TrueColor. Pixel format:
  32 bits per pixel.
  Least significant byte first in each pixel.
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```



Bind Shell Backdoor Detection

Anche questa è una debolezza critica, come quella precedente, ma il livello di criticità è leggermente minore: 9.8.

Questa debolezza indica che una shell è in ascolto su una porta remota senza che sia richiesta alcuna autenticazione. A causa di questa porta c'è il rischio che un aggressore possa connettersi tramite essa inviando, così, comandi direttamente.

Soluzione a questa problematica è impedirne l'accesso tramite una modifica tramite firewall su entrambe le macchine. Bisogna prestare attenzione in quanto questa è una contromisura temporanea perché il codice della backdoor è ancora nel sistema e potrebbe aggirare anche l'intervento effettuato.

passaggi metasploitable

```
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 1524 -j drop

msfadmin@metasploitable:~$ sudo iptables -L
Chain INPUT (policy ACCEPT) 61 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
target      prot opt source                destination
DROP dnet tcp -- anywhere (1 up) scan anywhere 5 seconds tcp dpt:postgresql
DROP        tcp -- anywhere              anywhere      tcp dpt:smtp
DROP gnet tcp -- anywhere              anywhere      tcp dpt:ingreslock
```

passaggi Kali

```
(kali㉿kali)-[~] ACCEPT
└─$ nmap -p 1524 192.168.50.101
Starting Nmap 7.95 ( https://nmap.org ) at 2025-05-18 14:21 EDT
Nmap scan report for 192.168.50.101
Host is up (0.00018s latency).
ACCEPT tcp -- 192.168.50.100 anywhere tcp dpt:postgresql
ACCEPT tcp -- 192.168.50.100 anywhere tcp dpt:smtp
ACCEPT tcp -- 192.168.50.100 anywhere tcp dpt:ingreslock
ACCEPT tcp -- 192.168.50.100 anywhere tcp dpt:ssh
PORT      STATE      SERVICE
1524/tcp  filtered  ingreslock
MAC Address: 08:00:27:CC:EB:61 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
target      prot opt source                destination
Nmap done: 1 IP address (1 host up) scanned in 0.35 seconds
```

NFS Shares World Readable

Qui abbiamo una debolezza con un livello di criticità decisamente inferiore alle due precedenti, ovvero 7.5.

Il server NFS remoto sta esportando una o più condivisioni senza limitare l'accesso: in base al nome host, all'IP o all'intervallo IP. A causa di questa mancanza di restrizioni di accesso, un aggressore potrebbe intercettare o manipolare le comunicazioni tra i server NFS e i client, soprattutto se la rete non è protetta o è vulnerabile a questi attacchi.

Per risolvere questo problema basta impostare le opportune restrizioni

su tutte le
condivisioni
NFS.

```
GNU nano 2.0.7      File: /etc/exports

# /etc/exports: the access control list for filesystems which may be exported
#                 to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes gss/krb5i(rw,sync)
#
# *(rw,sync,no_root_squash,no_subtree_check)
```

```
GNU nano 2.0.7      File: /etc/exports

# /etc/exports: the access control list for filesystems which may be exported
#                 to NFS clients.  See exports(5).
#
# Example for NFSv2 and NFSv3:
# /srv/homes      hostname1(rw,sync) hostname2(ro,sync)
#
# Example for NFSv4:
# /srv/nfs4       gss/krb5i(rw,sync,fsid=0,crossmnt)
# /srv/nfs4/homes gss/krb5i(rw,sync)
#
# /data 192.168.50.100(ro,sync,root_squash)
```

Debian OpenSSH/OpenSSL Package Random Number Generator Weakness

Anche questo è una debolezza con un livello di criticità 10.0. Qui la chiave host SSH remota è stata generata su un sistema Debian o Ubuntu che contiene un bug nel generatore di numeri casuali della sua libreria OpenSSL. Il problema è dovuto alla rimozione da parte di un pacchettizzatore Debian su quasi tutte le fonti di entropia nella versione remota di OpenSSL. Le porte che sono interessate sono la 22, la 25 e la 5432.

A causa di questa debolezza un aggressore può facilmente ottenere la parte privata della chiave remota e utilizzarla per decifrare la sessione remota.

Per risolvere questo problema bisogna considerare tutto il materiale crittografico generato sull'host remoto come indovinabile. In particolare, tutto il materiale delle chiavi SSH, SSL e OpenVPN dovrebbe essere rigenerato. Dato che è irrisolvibile in questi casi per mitigare il più possibile è anche qui necessario usare delle regole firewall, lasciando solamente il libero accesso alla nostra macchina Kali in modo tale da poterci collegare tramite la porta 22 compromettendo, così, la rivelazione di criticità da parte di Nessus.

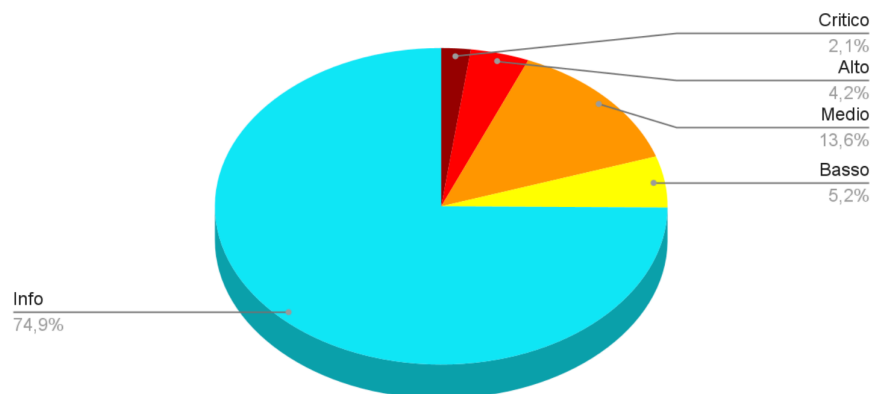
```
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 22 -s 192.168.50.100 -j ACCEPT
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 22 -j DROP
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 25 -j DROP
msfadmin@metasploitable:~$ sudo iptables -A INPUT -p tcp --dport 5432 -j DROP

msfadmin@metasploitable:~$ sudo iptables -L
[sudo] password for msfadmin:
Chain INPUT (policy ACCEPT)
target     prot opt source                destination            tcp dpt:postgresql
DROP       tcp  --  anywhere              anywhere               tcp dpt:smtp
DROP       tcp  --  anywhere              anywhere               tcp dpt:ingreslock
ACCEPT     tcp  --  192.168.50.100        anywhere               tcp dpt:ssh
DROP       tcp  --  anywhere              anywhere               tcp dpt:ssh

Chain FORWARD (policy ACCEPT)
target     prot opt source                destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source                destination
```

Dopo aver eseguito tutte le modifiche per mitigare le vulnerabilità, possiamo procedere con la scansione tramite Nessus in modo da verificare che esse siano effettivamente risolte o quantomeno mitigate.



Come possiamo vedere alcune vulnerabilità non sono state risolte del tutto ma sono state mitigate abbastanza per non facilitare troppo i possibili attaccanti ad accedere alla macchina.

Perciò, durante la prima scansione con Nessus, abbiamo rilevato un ampio numero di problematiche. Successivamente, sono state applicate una serie di contromisure mirate, come ad esempio le restrizioni firewall o la modifica di alcune impostazioni.

Nella seconda scansione abbiamo notato una riduzione generale del rischio, pur evidenziando la permanenza di alcune vulnerabilità non completamente risolvibili nel contesto simulato.

Per concludere è molto importante eseguire un processo ciclico di valutazione e miglioramento continuo ottimizzando la sicurezza della macchina per ridurre la superficie d'attacco e limitare i rischi.